RELATÓRIO TÉCNICO

Relatório de Auditoria de Segurança

Agente Storyteller

2026-10-16

Worktree b008. React/TypeScript, FastAPI/Python e SQLite orientado a eventos. Cinco categorias da skill; correções expressamente autorizadas.

Estado ao encerrar: 2 achados confirmados e corrigidos; 0 pendentes entre as causas confirmadas nesta auditoria. Nenhum narrador ou release foi admitido.

Método e contrato de confiança

Inventário integral dos handlers, rastreamento de serviços e persistência, reprodução sintética antes da correção e contraprovas depois. O produto aprovado tem um operador local confiável: isolamento foi mapeado para sessão, visibilidade e fronteira do navegador, não para um tenant inexistente.

Snapshot e proveniência

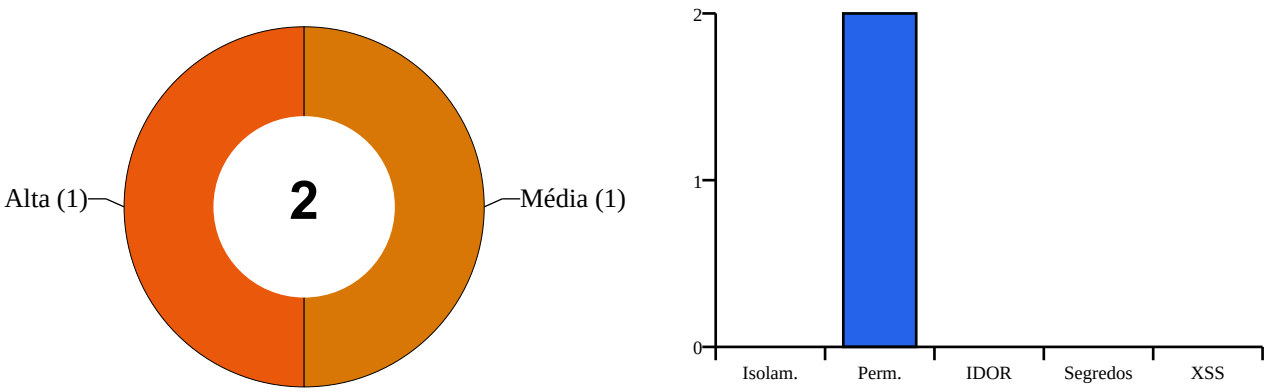
Branch codex/planejamento-agente-storyteller-v5; HEAD 5e563824fcba. O worktree contém alterações locais preexistentes; o código auditado não é o HEAD puro. Evidências anteriores não foram reescritas.

Sem serviços reais, credenciais, inferência paga, instalação de dependências, publicação de issues, commit ou push.

1. Resumo executivo

Contagens por causa única e severidade no momento da descoberta. Os gráficos não representam vulnerabilidades ainda abertas. Isolamento e IDOR relacionados a SEC-001 não foram contados duas vezes.

Severidade	Confirmados	Abertos
CRÍTICA	0	0
ALTA	1	0
MÉDIA	1	0
BAIXA	0	0
INFORMATIVA	0	0



Rosca: severidade. Barras: categoria primária; ambos os achados são falhas de permissão/fronteira no servidor. Zero nas demais categorias significa nenhum achado confirmado, não segurança garantida.

Verificação

7 regressões reproduziram as falhas antes da correção. Depois: 196 testes backend focados, mais 56 de transação/retomada/memória e 24 testes frontend aprovados. Os grupos backend são distintos. Suíte integral não repetida.

Limite do resultado

Os controles não são autenticação multiusuário, sandbox de processos locais ou autorização para expor o serviço. A escuta deve continuar em loopback.

2. Achados detalhados

ID / severidade	Arquivo:linha atual	Descrição / estado
SEC-001 ALTA	api/main.py:331 api/local_request_security.py:34 scripts/run_campaign_source_offline_trial.py:152	Fronteira local sem validação Host/Origin CORRIGIDO
SEC-002 MÉDIA	api/main.py:1976 api/main.py:2016	Consolidação do jogador incluía fontes privadas CORRIGIDO

As referências atuais apontam os locais de correção. As posições e trechos anteriores são identificados abaixo como baseline observado, sem confundi-los com linhas atuais.

SEC-001 - Fronteira local sem validação Host/Origin

SEVERIDADE ALTA | CORRIGIDO

Localização

api/main.py:331; api/local_request_security.py:34; scripts/run_campaign_source_offline_trial.py:152

Antes da correção: api/main.py:873 (WebSocket) e scripts/run_campaign_source_offline_trial.py:188 (bootstrap). Posições do estado local observado, não de um commit histórico.

Entrada e condição

Origin/Host de requisição de navegador; sessão conhecida ou padrão local_player. POST de retry não exige corpo. Site não confiável aberto pelo operador em navegador/ambiente que permita acesso site externo -> loopback; DNS rebinding depende do ambiente. Reprodução local ASGI, não exploração real.

Impacto e justificativa

Possível leitura/mutação de sessão conhecida ou disparo de operações locais/runtime. Host forjado também alcançava o bootstrap que distribui o token efêmero do ensaio. Uma causa única, não contada novamente como IDOR.

Trecho mínimo do baseline observado

```
async def websocket_endpoint(websocket: WebSocket, session_id: str):
    await websocket.accept()
# Sem gate Host/Origin antes do accept no baseline.
```

Correção executada

LocalRequestBoundary antes de todos os handlers principais e offline: exige Host loopback, recusa origem estrangeira/null e metadados duplicados. HTTP 403 e WebSocket 1008 antes do accept. Mantém mesma origem, desenvolvimento local explícito e automação nativa sem Origin.

Verificação e limite

Quatro regressões de fronteira falharam antes. Depois: seis POSTs, origens e headers ambíguos, bootstrap, fluxo nativo e HTTP/WebSocket legítimos. Não autentica pessoas nem contém processo local malicioso. O listener deve permanecer em loopback; headers não provam a interface de escuta. Sem autorização para publicar LAN/Internet.

SEC-002 - Consolidação do jogador incluía fontes privadas

SEVERIDADE MÉDIA | CORRIGIDO

Localização

api/main.py:1976; api/main.py:2016

Antes da correção: api/main.py:1971 (seleção de fontes). Reprodução com fontes sintéticas; dados reais de campanha não foram usados.

Entrada e condição

POST /session/{session_id}/memory/consolidate/{scope}, sem IDs ou com ID privado. Sessão com fontes storyteller/system. A factory conservava a classificação privada, mas a rota retornava o resumo inteiro ao jogador. Não requer quebrar SQLite ou credencial.

Impacto e justificativa

Divulgação de resumo/referências privados e segredos narrativos. A rota também podia suceder uma cadeia privada pelo caminho do jogador.

Trecho mínimo do baseline observado

```
rows = await store.list_episodic_memories(session_id)
# ... linhas intermediárias omitidas ...
memories.append(EpisodicMemory.model_validate(payload))
# ... resposta do endpoint ...
"consolidation": consolidation.model_dump(mode="json"),
```

Correção executada

Filtrar public/player antes da validação de IDs e do resumo. IDs privados se comportam como ausentes. Cadeia anterior privada causa recusa controlada sem expor ID/versão ou sobrescrever fontes. Sem migração/bifurcação do versionamento.

Verificação e limite

Três regressões falharam antes e passaram depois: seleção implícita, ID privado e cadeia privada. Resumo fundamentado e idempotência existentes preservados. Uma cadeia privada existente não pode ser atualizada por essa rota do jogador. Recusa deliberada para preservar a cadeia canônica única; sem API administrativa nova.

3. Cobertura por handler e categoria

Todos os 20 handlers explícitos foram inventariados por AST, sem falhas de parse, e rastreados na análise. A matriz estruturada registra as cinco categorias por handler.

Arquivo:linha / handler	Método e rota	Controle / resultado
api/main.py:733 receive_init_log	POST /api/initialization/logs	Fronteira local; sessão/SQLite; SEC-001/002 corrigidos
api/main.py:740 websocket_initialization	WEBSOCKET /ws/initialization	Fronteira local; sessão/SQLite; SEC-001/002 corrigidos
api/main.py:753 retry_initialization	POST /api/initialization/retry	Fronteira local; sessão/SQLite; SEC-001/002 corrigidos
api/main.py:819 health_check	GET /health	Fronteira local; sessão/SQLite; SEC-001/002 corrigidos
api/main.py:824 llm_capabilities	GET /api/llm/capabilities	Fronteira local; sessão/SQLite; SEC-001/002 corrigidos
api/main.py:841 test_llm_connection	POST /api/llm/test-connection	Fronteira local; sessão/SQLite; SEC-001/002 corrigidos
api/main.py:878 websocket_endpoint	WEBSOCKET /ws/session/{session_id}	Fronteira local; sessão/SQLite; SEC-001/002 corrigidos
api/main.py:1917 retrieve_player_context	GET /session/{session_id}/memory/context	Fronteira local; sessão/SQLite; SEC-001/002 corrigidos
api/main.py:1957 consolidate_memory	POST /session/{session_id}/memory/consolidate/{scope}	Fronteira local; sessão/SQLite; SEC-001/002 corrigidos
api/main.py:2037 award_xp	POST /session/{session_id}/xp/award	Fronteira local; sessão/SQLite; SEC-001/002 corrigidos
api/main.py:2074 upgrade_trait	POST /session/{session_id}/xp/upgrade	Fronteira local; sessão/SQLite; SEC-001/002 corrigidos
api/main.py:2130 serve_index	GET /	Fronteira local; sessão/SQLite; SEC-001/002 corrigidos
api/main.py:2143 serve_static_or_spa	GET /{catchall:path}	Fronteira local; sessão/SQLite; SEC-001/002 corrigidos
api/narrative_source_local_app.py:44 source_local_entry	WEBSOCKET /ws/source-local/{session_id}	Binding exato antes do accept; uma sessão/store
scripts/run_campaign_source_offline_trial.py:191 home	GET /	Fronteira local; token nos cinco endpoints API
scripts/run_campaign_source_offline_trial.py:195 start	POST /api/start	Fronteira local; token nos cinco endpoints API
scripts/run_campaign_source_offline_trial.py:205 session_status	GET /api/session/{session_id}	Fronteira local; token nos cinco endpoints API
scripts/run_campaign_source_offline_trial.py:210 action	POST /api/action	Fronteira local; token nos cinco endpoints API

Arquivo:linha / handler	Método e rota	Controle / resultado
scripts/run_campaign_source_offline_trial.py:233 resume	POST /api/resume	Fronteira local; token nos cinco endpoints API
scripts/run_campaign_source_offline_trial.py:249 operation_status	GET /api/operation/{session_id}/{operation_id}	Fronteira local; token nos cinco endpoints API

Inventário runtime adicional: GET/HEAD /openapi.json, /docs, /docs/oauth2-redirect e /redoc, mais mount /assets. Todos herdam a barreira do app principal. Groq/Luna montam a mesma factory B, sem handlers alternativos ocultos.

Isolamento de dono/tenant

Não aplicável como multi-tenant: um operador local confiável. Sessões/objetos são escopados em SQLite e B vincula sessão/store no servidor; não há isolamento por pessoa.

Permissão no navegador/servidor

Sem gates de papel no frontend: role é acessibilidade, não auth. Duas causas confirmadas no servidor foram corrigidas.

IDOR

IDs de sessão/operação foram rastreados em todos os handlers. Não foi criada causa duplicada por falta de owner_id num produto sem usuários; o vetor externo é SEC-001.

Segredos embutidos

Varredura mascarada de código, histórico e bundle. 14 indicadores atuais classificados como fixtures de teste; zero indicadores no histórico pelos padrões usados. .env e credenciais fora da leitura.

XSS

JSX renderiza texto, sem sink de HTML arbitrário encontrado; página offline usa textContent e token gerado pelo servidor. Testes com HTML malicioso passaram.

4. Pontos fortes, pontos fracos e limites

PROTEGIDO Transporte B opt-in compara Host, Origin e sessão exatos antes do accept, com store/configuração vinculados no servidor (api/narrative_source_local_selection.py:177-205).

PROTEGIDO Queries de sessão/operação usam parâmetros SQLite. Importação legada restringe alfabeto antes de criar caminhos (api/persistence.py:4881).

PROTEGIDO Catchall exige caminho resolvido contido em DIST_ROOT; teste de traversal passou (api/main.py:2149).

PROTEGIDO React entrega mensagens como texto. Testes de HTML malicioso cobrem narrativa, streaming e prévia B.

PROTEGIDO Ensaio offline exige token comparado em tempo constante em todos os cinco handlers API; bootstrap agora tem barreira Host/Origin.

PROTEGIDO SecretStr em configuração; auditoria sem .env ou validação de credenciais reais.

Pontos fracos observados

A confiança no localhost não estava aplicada à origem do navegador no fluxo padrão; a classificação privada das fontes não era aplicada na resposta da consolidação. Ambas as causas foram corrigidas, sem autenticação nova ou migração.

- Um operador local confiável, sem usuários/tenants/papéis. Não foi criado login nem isolamento por pessoa. A API não deve ser publicada sob esse contrato.

- 20 handlers explícitos, quatro rotas automáticas de documentação e um mount estático. Factories Groq/Luna reutilizam a entrada B inventariada.

- Scan heurístico mascarado exclui .env*, credenciais, saves, dependências e arquivos acima de 4 MB; não prova ausência universal de segredos.

- Histórico local não raso, 27 commits disponíveis, sem fetch. Bundle existente inspecionado, sem rebuild ou serviço real.

- Sem análise de CVEs/dependências, pentest de infraestrutura ou exploração real no navegador. Não é certificação nem garantia integral.

- Default JWT legado sem consumidor de autenticação no código: informativo, não vulnerabilidade explorável confirmada; não alterado.

- Suíte integral não repetida. Avisos de depreciação das dependências existentes, sem falha nos grupos executados.

- A correção do ensaio offline invalida manifestos congelados que o incluam. Não reescrever hashes históricos; próxima preparação deve congelar novamente seu próprio runtime antes de qualquer execução.

- Retomada antiga dizia L4 aguardando chave apesar do lote encerrado; reconciliar fatos sem inferir aceite narrativo.

- Revisão das alterações focada nas correções; quatro linhas com espaços finais preexistentes em main foram preservadas. Não é alegação de diff global sem avisos.

Extensão do scan

1063 arquivos textuais atuais; 182 blobs textuais históricos; 27 commits locais; clone não raso; bundle index-CS-kjDTq.js. Sem fetch remoto.

5. Recomendações priorizadas

P1

Manter correções e testes de regressão; continuar em loopback. Ambas as causas confirmadas foram corrigidas.

P2

Antes de retomar narrador, refazer preflight/manifesto prospectivo com fronteira corrigida, preservando lotes históricos. Nenhuma inferência nesta auditoria.

P3

Novas rotas devem herdar a barreira e a visibilidade; publicação multiusuário/LAN exige arquitetura própria. JWT inativo/CVEs ficam fora das correções oportunistas.

Reprodução

Na raiz do worktree, executar scan_local.py com Python do projeto e gerar_relatorio.py com o runtime documental que contém reportlab/pypdf/pypdfium2. Os testes e comandos exatos estão em README.md nesta pasta.

Aceitação

O relatório confirma correções e testes locais, não aceita narrador, campanha, arquitetura nova ou release. Não há achado confirmado desta auditoria aguardando credencial ou decisão humana para correção.

ISSUES PARA O GITHUB

Rascunho 1 de 2; nenhuma publicação executada. Texto Markdown completo abaixo.

--- ISSUE 1 ---

[Segurança] Fronteira local sem validação Host/Origin

Labels sugeridas: security, alta

Estado: corrigido localmente; rascunho de rastreabilidade, não publicado.

Problema

Origin/Host de requisição de navegador; sessão conhecida ou padrão local_player. POST de retry não exige corpo. Site não confiável aberto pelo operador em navegador/ambiente que permita acesso site externo -> loopback; DNS rebinding depende do ambiente. Reprodução local ASGI, não exploração real.

Evidência

Antes da correção: api/main.py:873 (WebSocket) e scripts/run_campaign_source_offline_trial.py:188 (bootstrap). Posições do estado local observado, não de um commit histórico.

- api/main.py:331 (correção atual)

- api/local_request_security.py:34 (correção atual)

- scripts/run_campaign_source_offline_trial.py:152 (correção atual)

```python

async def websocket_endpoint(websocket: WebSocket, session_id: str):

await websocket.accept()

# Sem gate Host/Origin antes do accept no baseline.

```

Impacto

Possível leitura/mutação de sessão conhecida ou disparo de operações locais/runtime. Host forjado também alcançava o bootstrap que distribui o token efêmero do ensaio. Uma causa única, não contada novamente como IDOR.

Correção recomendada / executada

LocalRequestBoundary antes de todos os handlers principais e offline: exige Host loopback, recusa origem estrangeira/null e metadados duplicados. HTTP 403 e WebSocket 1008 antes do accept. Mantém mesma origem, desenvolvimento local explícito e automação nativa sem Origin.

Verificação

Quatro regressões de fronteira falharam antes. Depois: seis POSTs, origens e headers ambíguos, bootstrap, fluxo nativo e HTTP/WebSocket legítimos.

Critérios de aceite

- [x] Origem estrangeira recusada antes de efeitos/accept.

- [x] Host de rebinding não lê bootstrap.

- [x] Fluxos locais legítimos preservados.

- [x] Nenhuma exceção testserver no servidor.

Limitações

Não autentica pessoas nem contém processo local malicioso. O listener deve permanecer em loopback; headers não provam a interface de escuta. Sem autorização para publicar LAN/Internet.

--- FIM ISSUE 1 ---

ISSUES PARA O GITHUB

Rascunho 2 de 2; nenhuma publicação executada. Texto Markdown completo abaixo.

--- ISSUE 2 ---

[Segurança] Consolidação do jogador incluía fontes privadas

Labels sugeridas: security, média

Estado: corrigido localmente; rascunho de rastreabilidade, não publicado.

Problema

POST /session/{session_id}/memory/consolidate/{scope}, sem IDs ou com ID privado. Sessão com fontes storyteller/system. A factory conservava a classificação privada, mas a rota retornava o resumo inteiro ao jogador. Não requer quebrar SQLite ou credencial.

Evidência

Antes da correção: api/main.py:1971 (seleção de fontes). Reprodução com fontes sintéticas; dados reais de campanha não foram usados.

- api/main.py:1976 (correção atual)

- api/main.py:2016 (correção atual)

```python

rows = await store.list_episodic_memories(session_id)

# ... linhas intermediárias omitidas ...

memories.append(EpisodicMemory.model_validate(payload))

# ... resposta do endpoint ...

"consolidation": consolidation.model_dump(mode="json"),

```

Impacto

Divulgação de resumo/referências privados e segredos narrativos. A rota também podia suceder uma cadeia privada pelo caminho do jogador.

Correção recomendada / executada

Filtrar public/player antes da validação de IDs e do resumo. IDs privados se comportam como ausentes. Cadeia anterior privada causa recusa controlada sem expor ID/versão ou sobrescrever fontes. Sem migração/bifurcação do versionamento.

Verificação

Três regressões falharam antes e passaram depois: seleção implícita, ID privado e cadeia privada. Resumo fundamentado e idempotência existentes preservados.

Critérios de aceite

- [x] Somente public/player no resumo entregue.

- [x] ID privado não concede acesso nem grava consolidação.

- [x] Cadeia privada preservada, sem vazamento de ID.

- [x] Resumo livre continua não canônico.

Limitações

Uma cadeia privada existente não pode ser atualizada por essa rota do jogador. Recusa deliberada para preservar a cadeia canônica única; sem API administrativa nova.

--- FIM ISSUE 2 ---